LetsDefend Incident Report: SOC Investigation

Security Operations Center (SOC) Incident Report

Executive Summary

Date and Time of Incident	05/29/2023, 01:01 PM
Incident ID	153-20232905-LD
Reported By	SOC Analyst Xavius Johnson
Location	Samuel/HRNetwork1/ Floris, Virginia
Incident Severity	High
Incident Status	Resolved

Incident Overview

On the afternoon of May 29, 2023, at precisely 01:01 pm, LetsDefend's Security Operations Center (SOC) detected a suspicious extension being added to an employee's browser. Initiated by a drive-by compromise attack leveraging user trust in well-known brands and a popular application store, the unauthorized software was poised to exfiltrate user cookies and session data from the following nodes within LetsDefend's HRNetwork1 infrastructure:

Samuel: A client host in the HR Department network.

LetsDefend's SOC successfully contained the threat, eliminated the malicious application, and restored compromised systems and accounts to their original state.

Key Findings

Owing to a lack of policies concerning browser extensions and the use of AI in the workplace, the unauthorized extension was installed by the employee seeking a legitimate application. Investigative efforts revealed that the unauthorized extension was installed only on the Samuel host and made multiple requests to known malicious domains used to collect victim cookies and data. As a result, Samuel's account and computer should be regarded as compromised.

Immediate Actions

All incident response procedures were carried out exclusively by LetsDefend's SOC without the involvement of external organizations. Immediate action was taken to isolate the infected host from the network and disable the affected account. Event logs were automatically collected using the LetsDefend SIEM.

Stakeholder Impact

Customers: No effect on customers is anticipated from this event, as it was contained quickly and the damage was limited.

Employees: In addition to the affected account, no other employees at LetsDefend will experience any setbacks.

Business Partners: No effect on Business Partners is anticipated from this event, as it was contained quickly and the damage was limited.

Internal Teams: The HR team may be affected by unauthorized data exfiltration by the extension. No effect on other Internal Teams is anticipated from this event, as it was contained quickly and the damage was limited.

Shareholders: No effect on Shareholders is anticipated from this, as it was effectively contained within a short time and the damage was limited.

Technical Analysis

Affected Systems & Data

Because there were no restrictions on installing extensions on work computers, the malicious extension was installed on the Samuel host within the HRNetwork1 Network. The affected systems are:

Samuel: A client host in the HR Department network that might store data concerning current employees and potential employees, depending on the role of Samuel in the HR Department. The unauthorized extension did make callbacks to known C2 servers, so concerns about user cookies and data on the host should be raised.

Evidence Sources & Analysis

On the afternoon of May 29, 2023, at precisely 01:01 pm, LetsDefend's SOC identified an unauthorized extension being added to an employee's browser. This was allowed by the EDR; however, it was triggered by the file hash and the command executed on the command line.

Figure 1: File hash identified as malicious on VirusTotal.

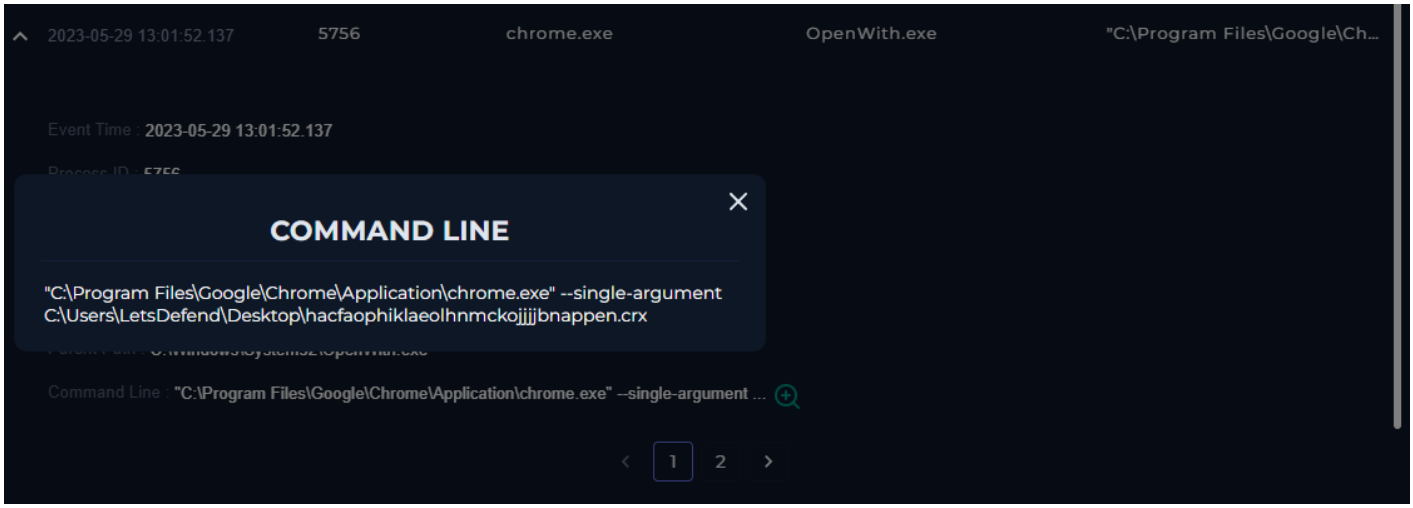


Figure 2: Command executed in CMD that triggered alert.

After this evidence was found, analysts investigated network and OS logs to determine whether a C2 had been contacted and whether data had been exfiltrated.

May, 29, 2023, 01:02 PM	OS	172.16.17.173	0	172.16.17.173	0
May, 29, 2023, 01:02 PM	Proxy	172.16.17.173	23324	52.76.101.124	80
May, 29, 2023, 01:02 PM	Proxy	172.16.17.173	34223	18.140.6.45	80
May, 29, 2023, 01:02 PM	OS	172.16.17.173	0	172.16.17.173	0
May, 29, 2023, 01:03 PM	OS	172.16.17.173	0	172.16.17.173	0
May, 29, 2023, 01:03 PM	Proxy	172.16.17.173	32242	172.217.17.142	80
May, 29, 2023, 01:03 PM	OS	172.16.17.173	0	172.16.17.173	0
May, 29, 2023, 01:06 PM	OS	172.16.17.173	0	172.16.17.173	0

Figure 3: Network and OS collected by the LetsDefend SIEM

Starting at 1:02 PM, the infected host performs DNS queries to obtain the IPs of malicious domains. The last DNS request of particular interest.

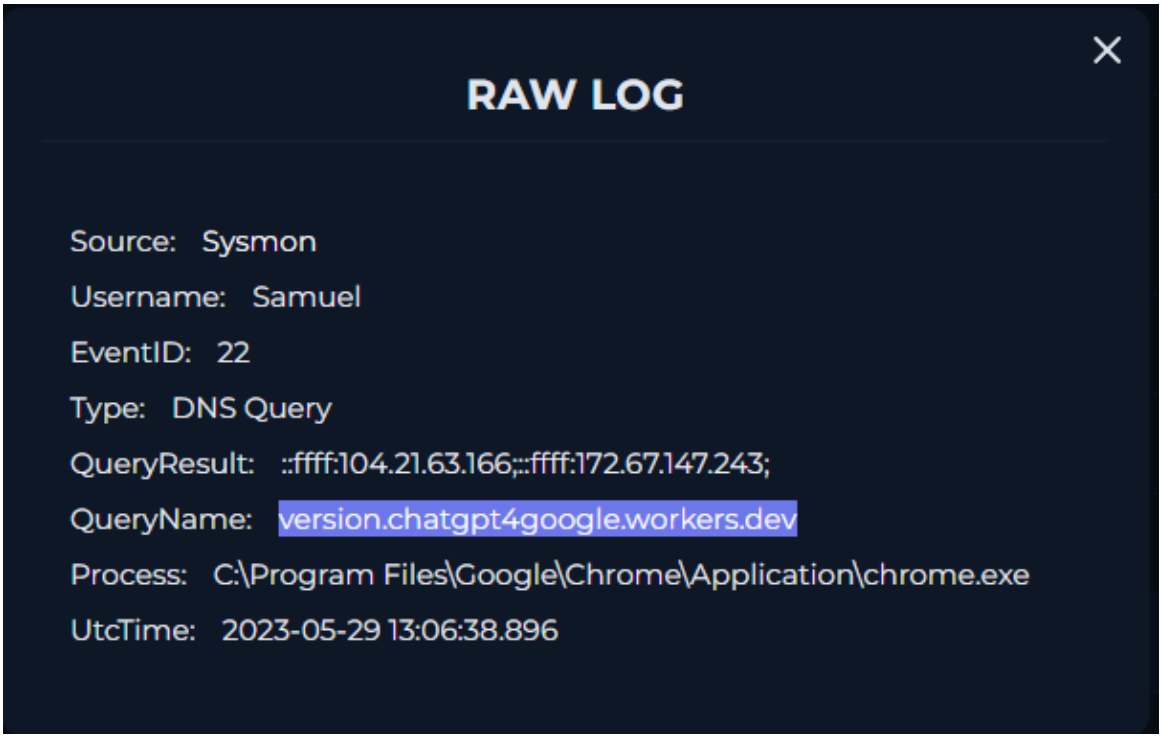


Figure 4: Sysmon log showing well know malicious domain used to steal cookies and user dat.

This domain is specifically mentioned in the file and behavior analysis conducted on VirusTotal.

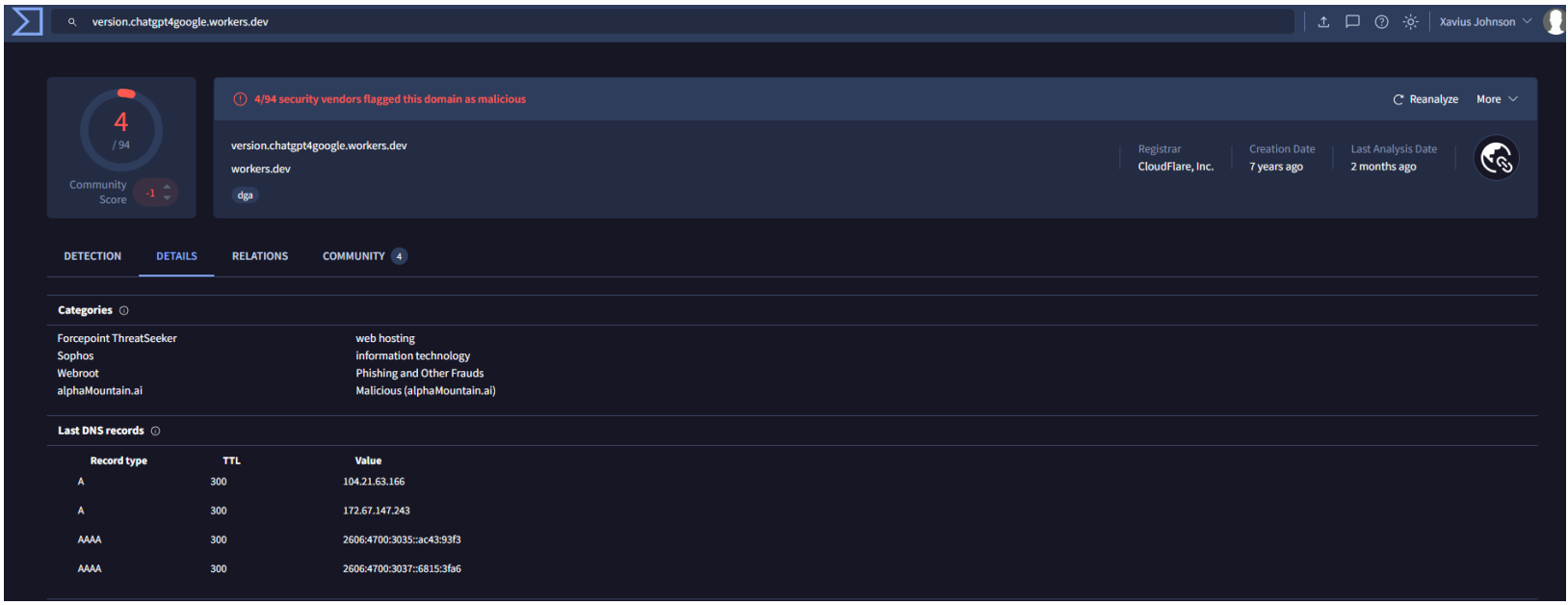


Figure 5: Further Details of known malicious domain on VirusTotal.

Indicators of Compromise (IoCs):

MD5 file hash:

7421f9abe5e618a0d517861f4709df53292a5f137053a227bfb4eb8e152a4669

C2 domain:

version[.]chatgpt4google[.]workers[.]dev

C2 IP address:

104[.]21[.]63[.]166

Root Cause Analysis

The root causes of this incident were a lack of policies governing AI use in the workplace, a lack of documentation on the acceptable use of browser extensions on company-owned devices, and insufficient employee awareness of malicious browser extensions.

Timeline

Initial Access- Drive-by Compromise T1189

May 29, 2023 1:01 PM An employee downloaded the malicious extension and installed it to chrome.exe.

Execution- User Execution: Malicious File T1204.002

May 29, 2023, 1:02 PM The employee installs the malicious extension and uses it as if it were legitimate software.

Command and Control- Application Layer Protocol: Web Protocols T1071.001

May 29, 2023, 1:03 PM The malicious extension uses chrome.exe to make DNS requests and resolve the C2 server, which is known to collect user cookies and data.

Containment Times

May 29, 2023, 1:15 PM LetsDefend's SOC analysts contained the infected host machine, isolating it from the internal and external network.

May 29, 2023, 1:20 PM The firewall rules were updated to block the known C2 IP address, effectively cutting off the unauthorized entity's remote access.

Eradication Times

May 29, 2023 1:25 PM LetsDefend analysts confirmed that the threat was contained and lacked any persistence mechanisms.

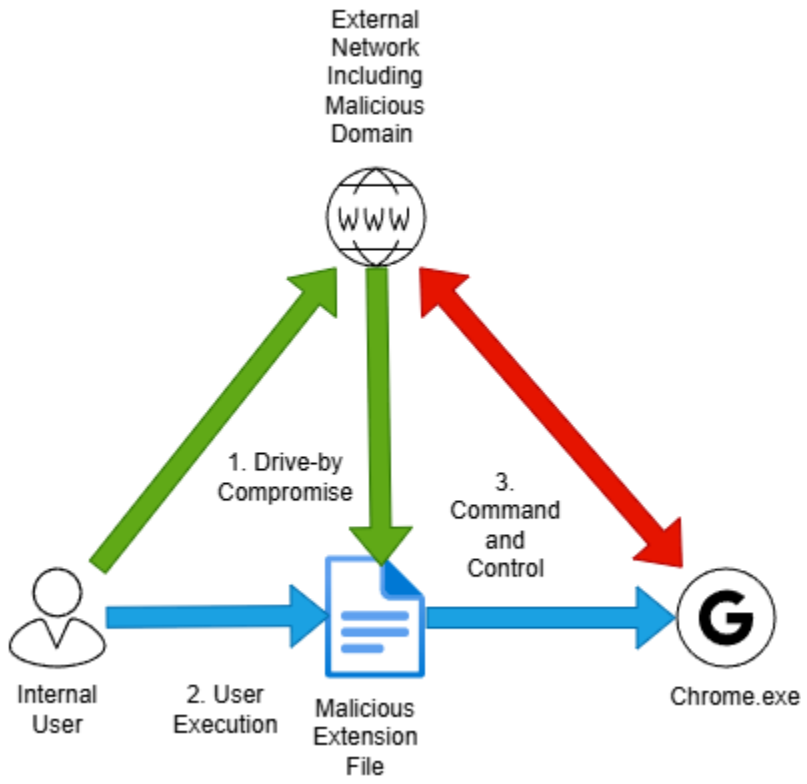
May 29, 2023, 1:35 PM The infected host was wiped and reimaged by using the company's default employee image. User files and settings were automatically applied to ensure minimal downtime.

Impact

Samuel's account was compromised; however, because of the quick action taken by LetsDefend's SOC, the extent of the damage was limited.

Lessons Learned

Gap Analysis: The incident highlighted a lack of policies governing AI and browser extensions. It also sheds light on how LetsDefends EDR handles suspicious extensions.

Recommendations for Improvement: Updated user awareness training, updated acceptable use policies, and up-to-date threat intelligence are suggested to counter future threats with similar TTPs.

Attack Vector Diagram